

Arquitetura da Plataforma de Processos Jurídicos

Documento técnico de referência: como o sistema está construído, que peças o compõem, porque é que cada uma é como é, e em que estado se encontra cada parte. Cobre a superfície do cliente, o back-office, o modelo de dados, a cadeia de auditoria, o canal de email, o arquivo documental e a infraestrutura.

SISTEMA

Onboarding KYC/AML

ENQUADRAMENTO

**Lei 83/2017 · Reg. 2/2020
OA · RGPD**

PRODUÇÃO

poc.terlicalabs.com

BASE DE CÓDIGO

**Next.js 16 · TypeScript
strict**

MODELO DE DADOS

29 tabelas · 15 migrações

COBERTURA

361 testes · 19 ficheiros

00

Índice e resumo

A plataforma tem duas metades com regras opostas — uma pública, autenticada por token de uso único, onde o cliente preenche o seu processo; outra privada, autenticada por sessão, onde a sociedade o gere. Tudo o resto no desenho decorre dessa separação.

SUPERFÍCIES

2

Cliente por token, back-office por sessão. Grupos de rotas distintos.

PASSOS DE ONBOARDING

7

Cada um em rota própria, com estado na base de dados.

CANAIS DE EMAIL

4

Resend, Mailjet, Brevo e SMTP próprio, em cascata.

01	O que a plataforma é	Enquadramento legal e as duas superfícies
02	Visão geral e stack	Camadas, tecnologias e porquê cada escolha
03	Organização do código	Rotas, features por domínio, caminho de uma escrita
04	O fluxo de onboarding	Os sete passos, condicionais e validação em dois lados
05	Ciclo de vida do processo	Oito estados, do rascunho ao arquivo
06	Modelo de dados	29 tabelas, uma por secção, listas em 1:N
07	Auditoria imutável	Cadeia de hashes garantida pela base de dados
08	Segurança e conformidade	Tokens, papéis, dados sensíveis e retenção
09	O canal de email	Seis templates, quatro canais, confirmação de entrega
10	Documentos e arquivo	PDFs gerados e sincronização SFTP
11	Infraestrutura e deploy	VPS, Coolify, Docker e migrações no arranque
12	Qualidade e estado atual	Testes, build, lint e o que falta

A auditoria é o produto

Num sistema de KYC sujeito à Lei 83/2017, o valor não está no formulário — está em conseguir provar, sete anos depois, quem declarou o quê, quando, e sobre que texto exato. É por isso que a imutabilidade vive na base de dados e não numa convenção de código.

01

O que a plataforma é

Plataforma de onboarding de clientes para um escritório de advogados, construída à volta dos deveres de identificação e diligência que a lei impõe antes de haver relação de negócio.

Enquadramento legal

Três regimes determinam o que o sistema tem de fazer, e nenhum é opcional:

REGIME	O QUE OBRIGA
Lei 83/2017	Identificação e diligência antes da relação de negócio; conservação dos elementos por sete anos; identificação de pessoas politicamente expostas.
Reg. 2/2020 OA	Deveres específicos do advogado no branqueamento de capitais, incluindo registo do processo de identificação.
RGPD	Consentimento com prova, minimização, direito ao apagamento — limitado pelo que a lei anterior obriga a conservar.

CONSEQUÊNCIA DE DESENHO

O direito ao apagamento e o dever de conservação de sete anos entram em conflito direto. A resolução no desenho: `apagado_em` esconde o processo da aplicação, uma rotina de expurgo só remove de facto passados os sete anos, e `evento_auditoria` nunca é tocado — regista *quem pediu o apagamento*, nunca os dados apagados.

As duas superfícies

A separação entre o que o cliente vê e o que a sociedade vê não é arrumação de ficheiros: são superfícies de segurança com regras opostas, e misturá-las é a forma habitual de haver fugas de dados.

	CLIENTE	ESCRITÓRIO
Quem entra	qualquer pessoa com o link	utilizador autenticado
Autenticação	token de uso único no URL	email + palavra-passe, sessão em BD
O que pode fazer	preencher e submeter o seu processo	consultar, filtrar, aprovar, rejeitar, reabrir
Onde vive	<code>src/app/(cliente)/</code>	<code>src/app/(backoffice)/</code>
Registo público	não aplicável	desativado — contas criadas no servidor

Quatro papéis

Dentro do back-office, o que se pode ver depende do papel. O papel `assistente` é o caso que mais pesa no desenho: não pode ver a declaração de PPE nem por URL direto nem por filtro na listagem — a tentativa fica registada na auditoria.

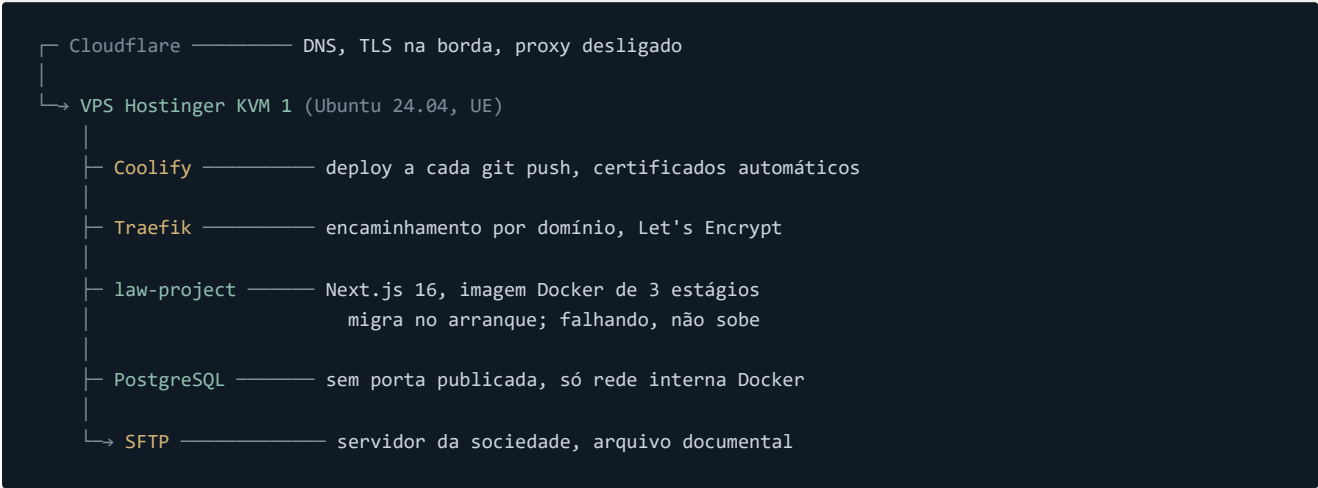
PAPEL	ALCANCE
admin	tudo, incluindo o diário de emails e a configuração
socio	processos, clientes, aprovação e rejeição
advogado	processos e clientes
assistente	processos sem a secção de PPE

O `/emails` é restrito a `admin` com o guard na própria página e não apenas na barra lateral: esconder a entrada da navegação não fecha o endereço a quem o escreva à mão.

02

Visão geral e stack

Uma aplicação Next.js única, servida de um contentor Docker num VPS europeu, com Postgres na mesma máquina e sem porta publicada para fora.



Stack aplicacional

CAMADA	ESCOLHA	RAZÃO
Framework	Next.js 16.2	Server Actions e Server Components eliminam a camada de API para escritas de formulário
Linguagem	TypeScript strict	zero <code>any</code> ; build limpo é critério de aceitação
UI	React 19.2 • Tailwind 4	tokens de design em CSS, sem tema em JavaScript
Componentes	shadcn/ui • radix-ui	primitivas acessíveis; o diálogo e o leitor de documentos assentam nelas
Base de dados	PostgreSQL • Drizzle	schema em TypeScript, migrações geradas e versionadas
Driver	postgres 3.4	<code>prepare:false</code> — compatível com poolers em modo transaction
Autenticação	Better Auth 1.6	sessões em BD de 8 horas; registo público desativado
Validação	Zod 4	o mesmo ficheiro de schemas corre no cliente e no servidor
Formulários	react-hook-form	com <code>@hookform/resolvers</code> sobre os mesmos schemas
Email	Resend + 3 canais	cascata com recurso; ver secção 09
PDF	pdf-lib	resumo do dossiê, capa e T&C gerados no servidor
Identificadores	uuidv7	ordenáveis por tempo; gerados na aplicação porque o Postgres só os tem nativos na v18
Estado no URL	nuqs	filtros do back-office partilháveis por link
Testes	Vitest • PGlite	unitários e migrações validadas num Postgres em WASM

Três escolhas de infraestrutura, e o que as motivou

VPS, NÃO VERCEL

20 €

O plano Hobby proíbe uso comercial; o Pro são 20 €/mês *por projeto*. Um custo fixo que não cresce com o número de clientes é melhor negócio.

POSTGRES PRÓPRIO

7 dias

O plano gratuito do Supabase suspende ao fim de 7 dias sem uso — exatamente o padrão de uma POC mostrada de duas em duas semanas.

FORNECEDOR DA UE

RGPD

O sistema guarda documentos de identificação e declarações de PPE. Um fornecedor americano traz exposição ao Cloud Act mesmo com datacenter europeu.

A imagem de produção assenta em `node:22-bookworm-slim` e não em Alpine: o `curl` do Alpine é compilado sem libssh2 e não fala `sftp://`, o que partia a sincronização do arquivo na primeira submissão. O Dockerfile verifica-o no build — sem sftp, a imagem não se constrói.

03

Organização do código

Organizado por domínio e não por tipo de ficheiro: quem mexe no onboarding mexe num sítio só, em vez de saltar entre quatro diretórios para uma alteração.

```
src/
  app/
    (cliente)/onboarding/[token]/      fluxo público, autenticado por token
      page · passo/[n] · submetido
    (backoffice)/                      autenticado por sessão
      page · processos · processos/[id] · clientes · emails · configuracao
    (auth)/entrar                      login; sem registo público
    termos-condicoes                  T&C em página própria
    api/auth/[...all]                  Better Auth
  features/                           por domínio
    onboarding/  19 ficheiros · schemas · passos · dados · acoes · componentes
    processos/   10 ficheiros · criação, link mágico, aprovação
    emails/      3 ficheiros · diário e rótulos
    auditoria/   4 ficheiros · hash encadeado e escrita
    clientes/ · conta/ · configuracao/
  db/           schema (10 ficheiros) · migrations (15)
  lib/          validacao-pt · token · email · emails/ · storage/ · sessao · termos
  components/   vocabulário visual partilhado
```

O caminho de uma escrita

Cada passo gravado percorre sempre a mesma sequência. A validação corre duas vezes de propósito, com **o mesmo ficheiro de schemas** nos dois lados — é o que impede o erro clássico de apertar o formulário e deixar a ação aberta.

```
Formulário (cliente)
└─ Zod valida ..... conforto: erros imediatos
   └─ Server Action
      └─ normaliza e revalida o token .. é um endpoint público como outro qualquer
      └─ Zod outra vez ..... o cliente nunca é fonte de verdade
      └─ upsert da secção
      └─ regras de negócio ..... PPE → risco elevado (e reposição)
      └─ evento de auditoria ..... passo.N.gravado
```

Uma regra aprendida a doer

TUDO O QUE CORRE DEPOIS DE UM INSERT CORRE NO SEU PRÓPRIO TRY

O envio do email de registo vive atrás de um `if`, e entre o `INSERT` do processo e esse `if` havia três `await` sem relação nenhuma com email — os cabeçalhos do pedido, o evento de auditoria e o cálculo da origem pública. Qualquer um a lançar produzia, ponto por ponto, o mesmo ecrã: processo criado e visível, diário de emails a zero, nenhum evento de link na auditoria, e uma mensagem de erro que se lia como falha de rede. Uma avaria em código de auditoria a apresentar-se como avaria de email, e a apagar o próprio rasto pelo caminho.

A regra que ficou: a partir do `INSERT`, cada passo corre dentro do seu próprio `try` e a ação tem uma saída só, levando sempre consigo o token em claro — que só existe naquela chamada. Seis casos ficaram fixados em teste, um por cada peça que pode rebentar; em todos, *o email foi tentado à mesma*.

Convenções

- Código, comentários, *commits* e interface em **português europeu**; identificadores de domínio em português.
- Qualquer identificador visível — referência, NIF, IBAN, hash, data de auditoria — é renderizado em `IBM Plex Mono`. Regra, não sugestão.
- Server Actions revalidam sempre com Zod no servidor; a validação do cliente é conforto.
- Segredos só em `.env`, com `.env.example` documentado e versionado.

04

O fluxo de onboarding

Sete passos, cada um em rota própria, com o estado na base de dados e não em memória: um refresh não perde nada e o cliente volta ao passo onde ficou.

#	PASSO	CONTEÚDO E CONDICIONAIS
1	Identificação do cliente	Ramifica particular/empresa — a escolha decide tudo o resto. Nome, contactos, nacionalidades (1:N), morada em sete campos.
2	Identificação fiscal	NIF/NIPC com <i>checksum</i> , documento de identificação, natureza jurídica obrigatória para pessoa coletiva. Anexos por Server Action à parte.
3	Representante Legal	SÓ PESSOA COLETIVA Uma pessoa singular representa-se a si própria — a pergunta não tem resposta possível e o passo é saltado.
4	PPE e relação de negócio	Declaração de pessoa politicamente exposta e origem dos fundos. Sugestões clicáveis por baixo de cada caixa. A secção mais sensível do sistema.
5	Dados para faturação	Número fiscal aceita formatos estrangeiros; o <i>checksum</i> português só se aplica a nove dígitos.
6	RGPD	Como chegou até nós (com «Outro» a abrir caixa livre), áreas de interesse, consentimentos de newsletter e convites.
7	Fecho	T&C, aceitação da proposta de honorários, declaração de veracidade e assinatura. Revisão de tudo antes de submeter.

A numeração não se mexe quando um passo é saltado: o Representante Legal continua a ser o 3 e o Fecho o 7. Renumerar partia os rótulos de auditoria (`passo.N.gravado`), a restrição `passo_valido` da base de dados e os links de «Corrigir» já gravados. O que muda é o percurso — a contagem do cabeçalho passa a «de 06».

O passo 7 e as duas leituras obrigatórias

Duas caixas do fecho só se destrancam depois de o respetivo documento ser aberto e percorrido até ao fim, à maneira da banca:

TERMOS E CONDIÇÕES

Renderizados dentro do leitor e não num `iframe` — assim o fim do documento é uma medição do próprio elemento, sem depender de o browser deixar ler a posição de outro documento. O mesmo texto está em `/termos-condicoes` e vai em PDF no email de boas-vindas: três sítios, uma fonte.

PROPOSTA DE HONORÁRIOS

Mesmo padrão. O que se lê no modal é a versão HTML legível do documento; o original oficial em PDF fica acessível por link. Um documento que caiba todo no ecrã conta como lido — senão a caixa ficava trancada para sempre num monitor grande.

Validações portuguesas

CAMPO	REGRA
NIF / NIPC	módulo 11; a mensagem de erro diz qual teria de ser o dígito de controlo
IBAN	módulo 97
Código postal	formato 0000-000
Telefone	formatos nacionais e internacionais
Datas	a data de constituição recusa o futuro

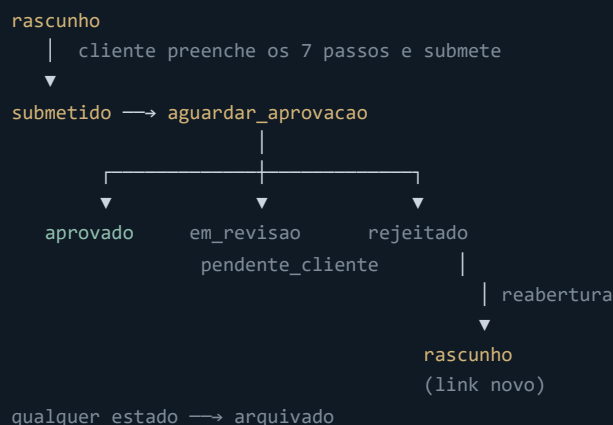
DETALHE QUE SÓ APARECEU A USAR

O React 19 faz *reset* ao formulário depois de uma Server Action passada em `action={}` . Um dígito errado no NIF apagava os outros dezanove campos. Passou a `onSubmit` com `preventDefault` .

05

Ciclo de vida do processo

Oito estados. O caminho normal atravessa quatro; os restantes existem para os casos em que a sociedade precisa de devolver o processo ao cliente ou recusá-lo.



ESTADO	SIGNIFICADO E EFEITO
rascunho	o cliente ainda está a preencher; o link abre no passo onde ficou
submetido	os sete passos estão gravados e a declaração final foi assinada
aguardar_aprovacao	à espera da decisão de um sócio ou advogado
em_revisao	em análise interna
pendente_cliente	devolvido ao cliente para completar
aprovado	dispara o email de boas-vindas com resumo, T&C e proposta em anexo
rejeitado	dispara o email de não aceitação; o motivo fica gravado no processo e na auditoria, mas não vai no corpo da mensagem
arquivado	fora da aplicação; o link do cliente diz que o dossiê foi arquivado

Reabertura

O texto de não aceitação abre expressamente a porta a «apresentar informação ou documentação complementar que permita uma nova apreciação». A reabertura é o que concretiza essa frase: o processo rejeitado volta a **rascunho**, recebe um **link novo** — não o antigo, que já circulou — e o cliente é avisado por email.

O link de acesso

Um link que não abre é a falha mais cara do sistema, porque a olho o URL parece bem. Cinco maneiras de um link *válido* não abrir foram fechadas:

#	FALHA	RESOLUÇÃO
1	o token apanha sujidade a caminho — ponto final da frase, <code><></code> do Outlook, espaço duro, barra do browser	normalização nas pontas antes de procurar; o hash normaliza antes de calcular
2	token e hash gerados em dois sítios diferentes	saem os dois da mesma função
3	colisão na tabela de tokens deixava um processo órfão	o erro de unicidade passa a distinguir referência de token
4	ninguém experimentava o link antes de o entregar	o servidor abre-o pela mesma função que serve a página do cliente; falhando, avisa no ecrã
5	havia dois links — um no email, outro montado no browser	o servidor monta-o uma vez e devolve-o à janela

E o 404 em si: a consulta devolvia `null` para tudo e as rotas respondiam-lhe com «esta página não existe». Passou a devolver quatro estados — `ok`, `expirado`, `arquivado`, `desconhecido` — para o cliente perceber o que aconteceu. Quem anda a adivinhar tokens continua a receber `desconhecido`; os outros três só são alcançáveis por quem já traz um token válido.

06

Modelo de dados

29 tabelas em 10 ficheiros de schema, com 15 migrações versionadas. As tabelas de secção são 1:1 com o processo — uma por passo do formulário.

```

organizacao —| utilizador
               |— contador_referencia      sequencial atómico por ano
               |— armazenamento_sociedade   credenciais SFTP, cifradas
               |— processo_onboarding —| dados_identificacao — nacionalidade (1:N)
                                     |— dados_fiscais — residencia_fiscal_adicional
                                     |— representante_legal — beneficiario_efetivo
                                     |— declaracao_ppe
                                     |— relacao_negocio
                                     |— preferencias_contacto —| email_newsletter
                                                             |— area_interesse
                                     |— dados_faturacao
                                     |— fecho_proposta
                                     |— documento
                                     |— assinatura
                                     |— consentimento — versao_texto_legal
                                     |— processo_token
                                     |— nota

evento_auditoria  append-only, encadeado por hash, fora da árvore
email_log         diário técnico do canal, uma linha por tentativa
  
```

Quatro decisões que moldam o schema

DECISÃO	RAZÃO
Uma tabela por secção, não um JSONB gigante	É preciso pesquisar por NIF, filtrar por PPE e indexar nome. O que se pesquisa é coluna; só o que é genuinamente variável vai para o <code>extra</code> JSONB de cada tabela.
Listas em tabelas 1:N	A pesquisa global tem de encontrar pelo NIF de um beneficiário efetivo, e isso não se faz dentro de um <code>array</code> JSON.
Morada como conjunto de sete colunas	Morada, país, localidade, código postal, freguesia, concelho e distrito — repetido em cliente, representante e faturação. Reutilizável e pesquisável.
IDs UUID v7 na aplicação	Ordenáveis por tempo, o que dá localidade de índice e paginação por cursor estável. Gerados em código porque o Postgres só tem <code>uuidv7()</code> nativo na v18 — consequência prática: qualquer <code>INSERT</code> em SQL cru tem de indicar o <code>id</code> .

Pesquisa em português

A pesquisa full-text é alimentada por *trigger* e não por coluna gerada: o `unaccent` não é *immutable* e as fontes — nome, NIF — vivem noutras tabelas. Quatro *triggers* mantêm o índice, e a configuração `pt_unaccent` resolve acentos e maiúsculas. Uma pesquisa por «maria silva» encontra «Maria Sílvia».

As 15 migrações

#	MIGRAÇÃO	O QUE TRAZ
0000	esquema inicial	as tabelas de base
0001	pesquisa_full_text_pt	<i>triggers</i> e <code>unaccent</code>
0002	auditoria_imutavel	<code>RULE</code> e <code>REVOKE</code>
0005	adiciona_tc_aceitacao	aceitação dos T&C no fecho
0007	armazenamento_so_sftp	remove OneDrive e WebDAV do schema
0008	email_log	diário de emails
0009	dados_abertura	dados recolhidos na criação do processo
0010	email_entrega	estados de entrega, canal e id da mensagem
0011-0012	canal_mailjet · canal_smtp	canais de recurso
0013	fluxo_aprovacao	estado <code>aguardar_aprovacao</code> e aceitação da proposta
0014	template_reabertura	sexto template de email

As migrações são validadas sem servidor nenhum: `pnpm db:validar` aplica-as todas num Postgres em WASM, conta as tabelas, confirma que a auditoria recusa mesmo `UPDATE` e `DELETE` e que a pesquisa resolve acentos. É o que garante que o primeiro `db:migrate` contra produção não rebenta.

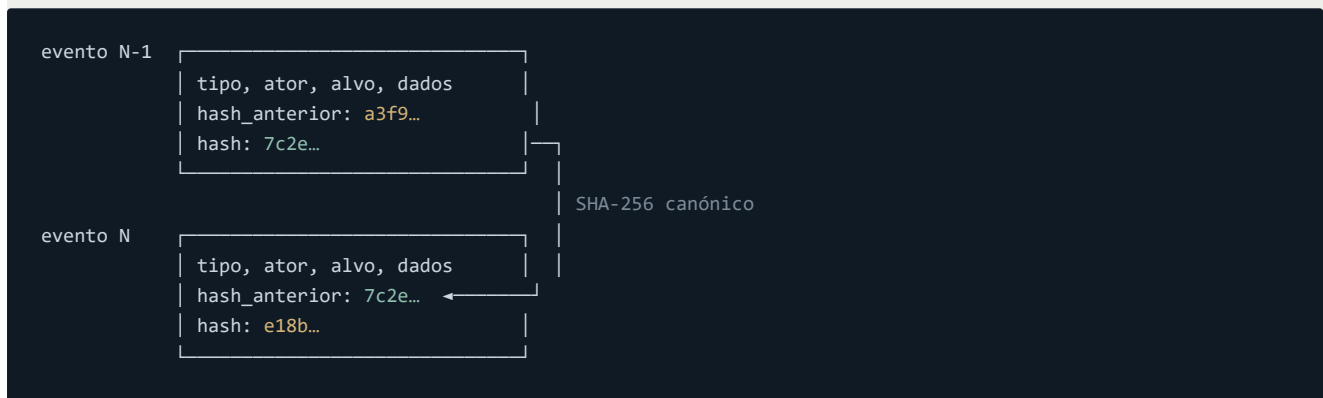
07

Auditoria imutável

A razão de ser do sistema, não um apêndice. Cada linha de `evento_auditoria` inclui o hash da anterior, e a imutabilidade está garantida pela base de dados — não por uma convenção de código que alguém possa contornar.

A cadeia

A cadeia é **por organização** e não global: uma cadeia única serializaria todas as escritas do sistema num só ponto de contenção. A serialização é **canónica**, com as chaves ordenadas a qualquer profundidade — sem isso, o mesmo objeto serializado por dois caminhos dá hashes diferentes e a cadeia parece adulterada sem estar.



A imutabilidade está no Postgres

```
-- migração 0002
CREATE RULE evento_auditoria_sem_update AS ON UPDATE TO evento_auditoria DO INSTEAD NOTHING;
CREATE RULE evento_auditoria_sem_delete AS ON DELETE TO evento_auditoria DO INSTEAD NOTHING;
REVOKE UPDATE, DELETE, TRUNCATE ON evento_auditoria FROM app_user;
```

Verificado em produção e em cada validação de migrações: `UPDATE` e `DELETE` devolvem **zero linhas afetadas**, e o `INSERT` continua a funcionar.

BURACO CONHECIDO, REGISTADO E NÃO RESOLVIDO

O `REVOKE` não morde enquanto o utilizador da aplicação for também o *owner* da tabela — e o *owner* contorna sempre um `REVOKE`. Neste momento, só as `RULE` protegem de facto. Criar um papel `app_user` distinto do *owner* é o passo que fecha isto; a migração 0002 já o aplica se o papel existir.

O que fica registado

A auditoria não regista apenas o que correu bem. Vários eventos existem precisamente para responder a perguntas que, sem eles, ficariam sem resposta:

EVENTO	A PERGUNTA A QUE RESPONDE
processo.criado	quando é que o dossiê nasceu, e por ordem de quem
passo.N.gravado	que secções foram preenchidas e quando
risco.reposto	uma PPE declarada e depois corrigida para «Não» — o risco baixa, e fica escrito porquê
link.sem_email	o processo nasceu sem endereço; o email não falhou, nunca foi pedido
link.nao_resolve	o link foi gerado e não abre — descoberto por nós, não pela reclamação
processo.rejeitado	a decisão e o seu motivo, que não viaja no email

O `email_log` não é auditoria e não a substitui. É o diário técnico do canal, que se trunca sem consequência; guarda o *hash* do token e nunca o token em claro, e não guarda o corpo das mensagens — duplicar dados pessoais numa tabela de diagnóstico é multiplicar superfície RGPD sem nada ganhar.

08

Segurança e conformidade

O token do link mágico

Guardado apenas em SHA-256. O valor em claro existe uma vez, no ecrã de criação do processo e no email — quem tiver leitura da base de dados não fica com a chave de todos os dossiês. A comparação é em tempo constante, para o tempo de resposta não deixar adivinhar o token byte a byte.

A limpeza do token é feita **só nas pontas**. Cortar o meio faria de um token corrompido um token possivelmente válido, que é esconder a avaria; nas pontas não há esse risco, porque o comprimento é fixo e nenhum token é prefixo de outro.

Autenticação do back-office

- Email e palavra-passe, com sessões em base de dados de **8 horas** — um dia de trabalho, não um mês.
- **Sem registo público**: o ecrã foi apagado e o *endpoint* da API desativado — a rota continuava a aceitar quem a chamasse à mão, mesmo sem página.
- As contas criam-se no servidor por script, com o *hash* vindo do próprio pacote de autenticação e não de uma reimplementação — é a única forma de garantir que os parâmetros do *script* não divergem numa atualização.

Dados sensíveis

O passo 4 — PPE e origem de fundos — é a informação mais sensível do sistema. O papel **assistente** não o pode ver, e o fecho é em dois sítios: o detalhe esconde-lhe a secção e regista a tentativa, e o filtro `?ppe=sim` da listagem é ignorado no servidor — sem isso, dava-lhe a mesma informação em bloco a partir do URL.

Uma PPE declarada força `nivel_risco = elevado`. Não é configurável: é o que a lei exige. E o risco, ao contrário do que estava, **desce** quando a declaração é corrigida — antes só subia, e um processo ficava em risco elevado para sempre por causa de uma resposta que entretanto tinha mudado.

Assinatura

Assinatura eletrónica **simples**. O que vale como prova não é o desenho da rubrica: é o conjunto de quem assinou, de que endereço, a que horas do **relógio do servidor** — nunca o do cliente — e sobre que conteúdo exato. O `hash_documento` é o SHA-256 do dossiê inteiro em serialização canónica no momento da assinatura; alterar um campo depois disso faz o hash deixar de bater.

Nem esta abordagem nem integrar uma ferramenta de assinatura dariam assinatura **qualificada**: para isso é preciso um prestador qualificado de serviços de confiança (Chave Móvel Digital, Cartão de Cidadão). A rubrica é hoje guardada em base64 numa coluna — aguenta uma POC, não aguenta escala; o certo é um *bucket* privado com a chave na base de dados.

Consentimentos com prova

Cada consentimento aponta para uma linha de `versao_texto_legal`, e a procura é por **chave e versão**. Antes procurava a linha mais recente da chave, e isso significava que mudar o articulado no código nunca chegava a uma instalação a correr — o cliente consentia o texto antigo enquanto o ecrã lhe mostrava o novo. Ao substituir um texto legal, subir também a versão: é ela que fica gravada junto do consentimento, e mudar o texto sem mudar a versão apaga a diferença entre o que o cliente aceitou e o que passou a estar escrito.

Retenção

Desenho descrito na secção 01. **Precisa de validação jurídica** — não é decisão técnica.

O canal de email

Seis templates, quatro canais em cascata e confirmação de entrega por sondagem. A parte do sistema que mais avarias produziu, e a que hoje mais se explica a si própria.

Os seis emails

TEMPLATE	ASSUNTO	MOMENTO
registo	JMASSANO Registo	a sociedade cria o processo; leva o link
confirmacao_rececao	Confirmação de Receção dos seus Dados	o cliente submete
boas_vindas	Bem-vindo à JMASSANO	o processo é aprovado; leva resumo, T&C e proposta em anexo
rejeicao	JMASSANO Feedback Registo	o processo é rejeitado
reabertura	JMASSANO Processo reaberto	um processo rejeitado volta a rascunho
notificacao_backoffice	aviso interno	a sociedade é avisada de uma submissão

Os textos dos primeiros seguem, à letra, os documentos entregues pelo cliente — incluindo «Registo», que é como lá está e não se corrigiu para «Registo», e a assinatura em aberto («Assinatura do Advogado gestor do Cliente»), que é o espaço deixado ao advogado que gere cada cliente.

Quatro canais, em cascata

O Resend vem primeiro por ser o mais fiável na entrega, mesmo tendo a quota gratuita mais curta. Falhando ele, tenta-se o seguinte — ser o primeiro não é ser o único, e uma conta suspensa ou uma quota esgotada não podem parar o onboarding.

ORDEM	CANAL	QUOTA GRATUITA	PAPEL
1	Resend	100/dia • 3.000/mês	canal principal
2	Mailjet	200/dia	primeiro recurso
3	Brevo	300/dia	segundo recurso
4	SMTP próprio	sem limite	último recurso, no servidor da sociedade

Um erro de quota diária põe o canal em pausa até ao fim do dia UTC, em vez de o tentar a cada mensagem. O custo assumido desta cascata é a hipótese de um duplicado, se um canal aceitar a mensagem e a resposta se perder.

«Aceite» não quer dizer «entregue»

O DEFEITO QUE ORIGINOU ESTA PARTE DO DESENHO

Num teste de vinte empresas, **um** dos emails ficou registado como enviado e nunca chegou à caixa do destinatário. Sem erro no servidor, sem nada na consola, e — o que interessa — indistinguível na listagem dos dezanove que chegaram. A linha do diário era escrita no momento em que o fornecedor respondia 200, o que é uma afirmação sobre a *aceitação*, não sobre a entrega. Entre o 200 e a caixa há um servidor de destino que ainda pode recusar.

Hoje o estado tem cinco valores: `enviado` (o fornecedor aceitou; a entrega está por confirmar, e o rótulo no ecrã é **Aceite**), `erro`, `entregue`, `devolvido` e `queixa`. O desfecho é perguntado ao fornecedor aos 15 segundos, 45 segundos e 2 minutos e meio, e a linha fecha ao primeiro resultado. Um devolvido escreve o motivo e conta, no cabeçalho da página, para as mensagens que «não chegaram».

Sondagem e não *webhook*: o *webhook* seria a via certa num sistema a sério, mas custa um endereço público fora da autenticação, a verificação da assinatura — sem a qual é um botão para qualquer um marcar emails como entregues — e configuração no painel de *cada* fornecedor, que fica por fazer no dia em que se muda de conta. A sondagem corre no contentor de vida longa, usa a chave que já existe e funciona igual nos quatro canais.

O diário

A linha do `email_log` é escrita **dentro** da função de envio e não por quem a chama, e o template é parâmetro obrigatório: um caminho de envio novo não compila sem responder «que email é este». Sucesso e erro entram os dois — a pergunta que se faz é «o cliente recebeu alguma coisa?», e ela só tem resposta se as falhas ficarem gravadas com o motivo.

10

Documentos e arquivo

Cada processo produz uma pasta no servidor da sociedade, com os anexos do cliente e os documentos que a plataforma gera.

O que a plataforma gera

DOCUMENTO	CONTEÚDO E DESTINO
summary.pdf	Detalhe completo do processo. Vai para o arquivo e em anexo ao email de boas-vindas — gerado do mesmo sítio, para o cliente e a sociedade não fiquem com versões diferentes do mesmo documento.
dados_cliente.pdf	Capa com data, referência, nome, NIF e o índice dos ficheiros da pasta. O nome não é escolha nossa: é o que o auxiliar em Python já deixava em cada pasta, e por onde se procura o dossiê. Gera-se em último, quando já se sabe o que indexar, e não se indexa a si própria.
T&C em PDF	O articulado em vigor, na versão exata que o cliente aceitou, anexo ao email de boas-vindas.
custos.pdf	A proposta de prestação de serviços — o template oficial entregue pelo cliente, servido tal e qual.

Sincronização SFTP

Um só destino de armazenamento: o servidor da sociedade, por SFTP. O OneDrive e o WebDAV saíram do código, do schema e dos scripts. O protocolo fica fixo no schema de validação e não desaparece: é o que faz uma configuração antiga noutro protocolo rebentar à entrada em vez de ser tratada como SFTP.

TRÊS AVARIAS QUE SÓ APARECERAM EM PRODUÇÃO

- 1. Os nomes iam em cru no URL.** Uma pasta de cliente chama-se `Maria Silva (249886344)`, e o espaço não entra num URL: o pedido truncava aí e o ficheiro ia parar a `/Clientes/Maria`. Os segmentos passaram a ser codificados.
- 2. O comando de criar pasta parte a linha em palavras.** O caminho acabava no primeiro espaço e a pasta criada tinha o nome errado. Passou a ir entre aspas, com o escape devido.
- 3. A imagem base não falava SFTP.** Resolvido trocando a base do contentor — megabytes de imagem contra zero linhas de lógica.

Nomes de pasta

A sanitização preserva o ponto final de um nome de empresa («Lda.», «S.A.») e só o corta quando o nome *começa* por ponto, que é a forma de um ficheiro oculto. Contraria de propósito a regra de alguns sistemas de ficheiros: uma pasta com a denominação social errada é pior do que uma pasta com um nome que o servidor normaliza.

Anexos do cliente

As extensões e os tipos MIME aceites vivem **numa fonte só**, com o filtro do campo derivado dela. Estavam escritos em dois sítios e divergiram: o campo anunciava um formato que o servidor recusava, e como o campo se limpa sozinho depois de cada tentativa, ficava a parecer que anexar não fazia nada. O tipo MIME declarado manda quando é conhecido; só quando o browser não se compromete é que a extensão decide — um ficheiro que se diz HTML e se chama `.pdf` continua recusado.

O campo de anexo não é um campo do formulário: não tem `name`, não entra na carga do passo, e o upload é uma ação à parte disparada na escolha do ficheiro. O campo é limpo de propósito no fim — é isso que permite voltar a escolher o *mesmo* ficheiro depois de um erro. Ficou fixado em teste, porque duas investigações separadas o interpretaram como avaria.

11

Infraestrutura e deploy

Composição

CAMADA	ESCOLHA	NOTA
Domínio	Cloudflare Registrar	DNS; proxy desligado
Servidor	Hostinger VPS KVM 1, Ubuntu 24.04	1 vCPU, 4 GB, datacenter na UE
PaaS	Coolify, auto-alojado	deploy a cada <i>push</i> , TLS automático
Base de dados	PostgreSQL no próprio servidor	sem porta publicada
Email	Resend + Mailjet + Brevo + SMTP	cascata com recurso
Arquivo	SFTP no servidor da sociedade	credenciais cifradas em BD

A imagem

Docker em três estágios, com `output: "standalone"`. As migrações correm no arranque do contentor e, **se falharem, ele não sobe** — é preferível não haver serviço a haver serviço contra um schema que não é o esperado.

REGRA DE DEPLOY APRENDIDA

Testar contra uma imagem que não tem as correções mede o defeito antigo. Houve uma investigação inteira — três passagens — conduzida contra uma imagem anterior às correções que se procurava validar. Antes de voltar a testar em produção: correr os testes, o *typecheck*, commitar, aplicar as migrações e só depois fazer *deploy*.

Ferramentas de operação

Todas correm também dentro do contentor, que é onde interessa:

COMANDO	PARA QUÊ
<code>pnpm db:validar</code>	aplica as 15 migrações num Postgres em WASM e verifica-as, sem servidor nenhum
<code>pnpm auditoria:verificar</code>	revalida a cadeia de hashes de ponta a ponta
<code>pnpm email:testar <destino></code>	separa as três causas de «o cliente não recebeu nada» — chave que não chega ao ambiente, domínio por verificar, saída fechada — em segundos, sem criar processos a sério
<code>pnpm email:conferir</code>	confere as mensagens que ficaram em «Aceite» e fecha-lhes o estado; cobre o reinício a meio e o desfecho que chega tarde
<code>scripts/criar_utilizador</code>	cria contas do back-office no servidor (não há registo público)

Diagnóstico

Uma lição atravessa quase todas as avarias deste sistema: **o mesmo ecrã a significar coisas diferentes** é o que impede uma investigação de convergir. «0 mensagens» no diário de emails queria dizer, ao mesmo tempo, «não havia endereço», «havia e perdeu-se a caminho» e «tentou-se e a gravação falhou» — três causas que se resolvem em três sítios diferentes. O que fecha esse tipo de buraco não é o remendo: é fazer a plataforma dizer qual dos casos é.

12

Qualidade e estado atual

Verificação executada

VERIFICAÇÃO	RESULTADO	DETALHE
pnpm test	361 PASSAM	19 ficheiros, 2,0 s
pnpm typecheck	LIMPO	TypeScript strict, zero any
pnpm build	LIMPO	13 rotas compiladas
pnpm db:validar	VÁLIDO	15 migrações, 29 tabelas, 4 <i>triggers</i> , auditoria a recusar UPDATE e DELETE
pnpm lint	6 ERROS	ver em baixo

Onde estão os testes

ÁREA	O QUE FIXAM
validacao-pt	NIF módulo 11, IBAN módulo 97, código postal, telefone
auditoria/hash	determinismo, ordenação canónica, deteção de adulteração
token	normalização, hash idempotente, geração conjunta
email • smtp	cascata de canais, quota diária, confirmação de entrega, gravação em todos os caminhos
emails/jmassano	os textos batem com os documentos do cliente
processos/acoas	seis casos: cada peça a rebentar, e o email tentado à mesma
processos/aprovacao	aprovação, rejeição e reabertura, incluindo os emails a falhar
onboarding/schemas	condicionais por tipo de cliente, campos obrigatórios, formatos estrangeiros
storage/*	sanitização de nomes, cifra de credenciais, geração de PDFs, adaptador do servidor

O lint falha — seis erros

FICHEIRO

ERRO

Formulario.tsx:330	<code>setState</code> síncrono dentro de um efeito
Lombada.tsx:49	<code>setState</code> síncrono dentro de um efeito
use-mobile.ts:14	<code>setState</code> síncrono dentro de um efeito
LeitorProposta.tsx:105	acesso a <i>ref</i> durante o render
LeitorTermos.tsx:113	acesso a <i>ref</i> durante o render
smtp.ts:62	<code>prefer-const</code>

Os dois avisos de *ref* apanham o padrão corrente de guardar a versão mais recente de uma função numa *ref*, a correção é atribuí-la dentro de um efeito. Nenhum destes erros parte o *build* nem falha um teste, mas `pnpm lint` devolve código de saída 1 — o que torna qualquer verificação automática vermelha.

O que falta, por ordem de importância

1. **Papel `app_user` separado do `owner`**, para o `REVOKE` da auditoria morder de facto.
2. **E2E automatizado**. Não há Playwright nas dependências; o percurso continua a ser conduzido à mão. É o que falta para isto deixar de depender de alguém se lembrar de testar.
3. **Corrigir os seis erros de lint**, para a verificação automática voltar a verde.
4. **Beneficiários efetivos e RCBE**. Obrigação legal, schema pronto, sem interface.
5. **Articulado real dos T&C**. O texto atual é de demonstração, escrito a partir do que a lei obriga a constar — ao substituí-lo, subir a versão.
6. **Object storage** para a rubrica e os documentos, em vez de base64 em coluna.
7. **Validação jurídica** da retenção aos sete anos.
8. **Percurso Empresa validado contra imagens** — foi construído a partir do texto do brief, com risco de retrabalho assumido.

O diagnóstico é o produto

A maior parte do trabalho recente deste sistema não foi acrescentar funcionalidades — foi tornar visíveis as diferenças entre causas que davam o mesmo ecrã. É isso que separa uma plataforma que se opera de uma que se investiga.